Security Misconfiguration

Week 6 Notes | OWASP Top 10 | DG Cyber Security Internship | Diksha Uma Shankar Rao

What it is

Security Misconfiguration happens when an application, server, framework or cloud service is deployed with insecure settings. This may come from unsafe defaults, incomplete setup, unnecessary features left on, or missing hardening. These weaknesses often do not break in by themselves, but they make other attacks easier and leak useful information.

Common examples

- Default accounts and passwords left unchanged
- Debug mode or detailed error messages and stack traces shown to users
- Directory listing enabled on the web server
- Unnecessary services, ports, sample pages or features enabled
- Missing HTTP security headers (X-Frame-Options, Content-Security-Policy, HSTS, X-Content-Type-Options)
- Server banners revealing software and versions (for example X-Powered-By)
- Cookies missing the SameSite, Secure or HttpOnly flags
- Outdated software that has not been patched
- Publicly open cloud storage or admin panels

Findings from the OWASP ZAP scan in this project

- Missing Anti-Clickjacking Header: **Medium**. The page can be placed inside a frame, enabling clickjacking.
- Content Security Policy (CSP) Header Not Set: **Medium**. No browser-level protection against XSS.
- Cookie without SameSite attribute: **Low**
- Server version and X-Powered-By information leaks: **Low**
- The scan reported 9 distinct alerts (10 instances): 2 Medium, 5 Low, 3 Informational

Impact

Information disclosure that helps attackers plan, easier exploitation of other flaws such as XSS and clickjacking, and in serious cases unauthorised access to systems or data.

Prevention

- Use a repeatable **hardening baseline** and apply it to every environment
- Remove or disable unused features, accounts, services and sample files
- Set security headers on every response
- Turn off debug mode and show generic error pages in production
- Change all default credentials
- Patch and update software and libraries regularly
- Review configuration automatically and run regular vulnerability scans

Key takeaway

Secure defaults and regular configuration reviews close many easy doors for attackers.